Luca Danisi **19-3-2026**

Password craking and malware

1 - Objective : To retrieve password hashes from the DVWA database through SQL Injection and crack them with John the Ripper to demonstrate how weak MD5-based password storage can be compromised.

🧪 Our lab environment

🐉 **Kali Linux**: Attacker machine
💀 **DVWA** : target web application hosted on Metasploitable 2

The two systems were connected through an internal network, with Kali Linux configured as 192.168.50.100 and the target as 192.168.50.101.

2 – Tools Used :

Kali Linux — attacker machine used to access the target, save the extracted hashes, and run John the Ripper.

Metasploitable / DVWA — vulnerable target environment hosting Damn Vulnerable Web Application, used to perform the SQL Injection attack and retrieve password hashes from the database.

Web Browser — used on Kali to open DVWA, log in, set the security level to Low, and submit the SQL Injection payload.

John the Ripper — password cracking tool used to crack the extracted raw MD5 hashes offline.

hashes.txt — local text file created to store the extracted username:hash pairs before cracking.

3 - Results :

DVWA Exploit ✅ → The SQL Injection attack successfully exposed the usernames and password hashes stored in the DVWA database :

- Usernames and MD5 password hashes were extracted from DVWA.

- The hashes were saved into hashes.txt.

- John the Ripper successfully cracked all 5 passwords.

- Most passwords were recovered through the default wordlist, while one required incremental/brute-force mode.

- The lab confirmed the weakness of storing passwords with unsalted MD5.

4 - Issues Encountered During the Test:

A few setup and execution points required attention during the lab. First, DVWA had to be configured with the security level set to **Low** so the SQL Injection attack could be performed successfully. Then, the extracted hashes needed to be saved in the correct format inside **hashes.txt** before running John the Ripper. Finally, not every password was recovered through the default wordlist, since one of them required **incremental/brute-force mode** to be cracked.

5 – Conclusion :

The lab showed that weak password storage and SQL Injection together create a serious security risk. By extracting MD5 hashes from DVWA and cracking them with John the Ripper, it was possible to recover all five passwords. This confirms why insecure hashing algorithms should be avoided and why web applications must be protected against SQL Injection.

Technical Walkthrough

1. ## Connectivity Check
   The lab started by verifying that the two virtual machines could communicate correctly over the internal network. A ping test confirmed successful connectivity between the attacker machine (**Kali Linux – 192.168.50.100**) and the target machine (**Metasploitable / DVWA – 192.168.50.101**). This step was necessary to make sure the environment was ready for the web attack and the later cracking phase.

2. ## Access to DVWA and basic configuration
   From Kali Linux, the DVWA web application was opened in the browser using the target IP address. The default credentials (admin / password) were used to log in, and the DVWA security level was set to **Low**. This configuration allowed the SQL Injection vulnerability to be tested in its intentionally insecure form.

3. ## Extraction of usernames and password hashes
   Inside the **SQL Injection** section of DVWA, a UNION-based SQL Injection payload was submitted to retrieve usernames and password hashes from the users table. The payload returned a list of user accounts together with their stored password hashes, demonstrating that sensitive authentication data could be exposed through improper input handling.

4. ## Saving the extracted hashes for offline cracking
   After retrieving the hashes, the output was saved into a local file named `hashes.txt`. This file was prepared to be used as input for John the Ripper during the offline cracking phase. Organizing the hashes into a separate file made it possible to move from web exploitation to password analysis in a structured way.

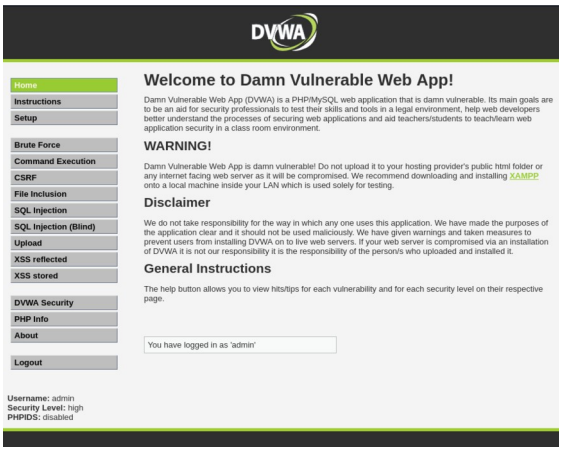
5. ## Password cracking with John the Ripper
   John the Ripper was executed against the collected hashes using the command `john --format=raw-md5 hashes.txt`. The tool first attempted to crack the hashes using its default wordlist and then continued with more advanced modes when needed. In the end, all five passwords were recovered. Most were found through dictionary-based matching, while one required **incremental / brute-force mode**, showing how weak and unsalted MD5 hashes can be cracked efficiently.

Screenshot captions

Figure 1 – Connectivity check between Kali and Metasploitable

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

Figure 2 – DVWA Login and Security Level Configuration



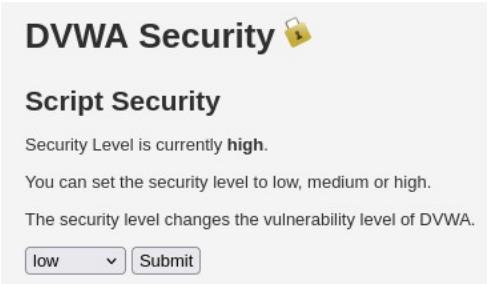
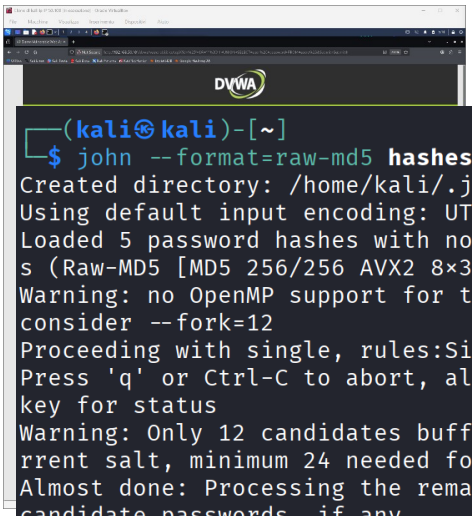


Figure 3 – SQL Injection output showing usernames and password hashes



```
┌──(kali㉿kali)-[~]
└─$ john --format=raw-md5 hashes.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salt
s (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type,
consider --fork=12
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other
key for status
Warning: Only 12 candidates buffered for the cu
rrent salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered
candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/passwo
rd.lst
password         (admin)
password         (smithy)
abc123           (gordonb)
letmein          (pablo)
Proceeding with incremental:ASCII
charley          (1337)
5g 0:00:00:00 DONE 3/3 (2026-03-24 05:23) 21.73
g/s 792460p/s 792460c/s 867243C/s stevy13..cand
ake
Use the "--show --format=Raw-MD5" options to di
splay all of the cracked passwords reliably
Session completed.
```

Figure 4 – John the Ripper successfully cracking the hashes

End